

Known Limitations — R3

- **Server authority, bounded revalidation.** Real-data access is decided server-side and revalidated on an interval capped at **300 seconds**. After a suspend/revoke, an already-open session retains access until its next revalidation ($\leq 300s$) or a forced sign-out. We do **not** claim instantaneous revocation. `revoke-pilot-access` and `disable-user` additionally call a global sign-out server-side, which invalidates refresh tokens immediately; the $\leq 300s$ bound covers the access-token window.
- **Local plan/role values are UX only.** They never grant real-data access. Hidden/disabled buttons are UX, not a security control; the server is authoritative.
- **MFA recovery** is an admin-driven **dual-control** reset (two distinct internal admins), enforced by a DB constraint. There is no self-service TOTP reset.
- **Email delivery** on staging uses Supabase's built-in service with low rate limits ($\sim 2\text{--}4/\text{hour}$) — adequate for testing only. Production SMTP is documented but not configured.
- **Staging validation outstanding.** MFA enrollment/challenge, invitation emails/links, session-revocation timing, and the data-boundary capture are **NOT VALIDATED IN STAGING** until the 16-step E2E executes against the supplied project.
- **Not built:** cleared-funds production activation gating, production Supabase project, backup/recovery validation, Phase 4 modularization.